

[대외비] (주)다운컨택 수탁자 현황 자료

1. 수탁자 기본 현황

- 회사명: (주)다운컨택 (Daon Contact Inc.)
- 대표자: 박지훈
- 설립일: 2015년 4월 1일
- 소재지: 경기도 성남시 분당구 판교로
- 직원 수: 총 215명 (IT인프라팀 12명, 운영지원 18명, 고객상담사 185명)
- 주요 사업: 콜센터 아웃소싱(BPO), CTI 기반 항공 CS 업무 운영
- ISMS-P 인증 보유 (인증 범위: CS 위탁 운영 및 개인정보처리)
- 개인정보보호책임자(CPO): 이미경 이사 (운영본부장 겸임)

2. 개인정보 위탁 업무 내역

- 위탁자: (주)하랑항공 (위탁 담당부서: 고객경험혁신팀)
- 위탁 업무: 하랑항공 고객센터 인바운드 CS 업무 대행
 - 항공권 예약·발권·취소·변경 전화 상담
 - 수하물 분실·파손·지연 접수 및 처리 상담
 - 마일리지 적립·사용·전환 관련 고객 응대
 - 불만 접수(VOC) 등록 및 처리 현황 안내
 - 24시간 365일 운영 (심야 전담 상담사 팀 별도 운영)
- 계약 기간: 2025년 5월 1일 ~ 2026년 5월 1일 (1년, 연간 자동 갱신 조항 포함)
- 개인정보 재위탁 현황
 - (주)스카이미세지: SMS 발송 업무 재위탁 (상담 완료 후 고객 확인 문자 발송)
 - 하랑항공 사전 서면 승인을 취득하였으며, 재위탁 계약서를 체결하고 있음
 - 다만, 재위탁 계약서 내 재수탁사 직원 교육 의무 조항·현장 보안 점검 허용 조항·손해배상 책임 범위 조항이 누락되어 있음
 - (주)스카이미세지에 대한 연 1회 정기 보안 점검을 실시하지 않고 있음

3. 처리하는 개인정보 항목 및 규모

- 데이터 접근 방식
 - (A) 위탁자 CRM: 하랑항공이 제공하는 Citrix VDI 환경을 통해 원격 접속하여 고객 정보를 조회 및 처리하고 있음 (데이터를 로컬에 직접 저장하지 않음)

- (B) 수탁자 자체 시스템: 상담 통화 녹취, 상담 이력 저장을 위해 (주)다운컨택이 자체 CTI 서버 및 상담로그 DB를 On-premise로 운영하고 있음
- (A) 위탁자 CRM (접근·조회 항목)
 - 성명, 고객 ID, 휴대폰 번호
 - 여권번호 (국제선 예약 고객)
 - 마일리지 번호·잔여 마일리지
 - 항공권 예약·발권 내역
 - 규모: 하랑항공 전체 회원 약 480만 명 데이터에 접근 가능 (월평균 인입 상담 약 28만 건)
- (B) 수탁자 자체 DB (저장 항목)
 - 고객 휴대폰 번호 (CTI 발신자 식별용)
 - 고객 성명 (상담 로그 기록)
 - 상담 로그 (텍스트): 상담 내용 요약, 처리 결과
 - 통화 녹취 파일 (음성 정보, .mp3/.wav)
 - 규모: 월평균 녹취 파일 생성 약 28만 건, 녹취 서버 용량 180TB
 - ※ 고객 휴대폰 번호·성명이 암호화 없이 평문(VARCHAR)으로 DB에 저장되고 있음 (개인정보보호법 시행령 제30조 위반)
 - ※ 통화 녹취 파일(.mp3/.wav)이 암호화 없이 녹취 서버에 평문으로 저장되고 있음

4. 개인정보 처리 시스템 현황 (논리적 망분리 환경)

- 시스템 구성
 - VDI 환경: 하랑항공이 제공하는 Citrix Virtual Apps & Desktops에 상담사 PC(1인 1 PC)에서 접속하고 있음
 - CTI 서버, 녹취 서버는 사내 서버실에 있음
 - 상담로그 DB는 사내 서버실(On-premise)에 있으며, MariaDB 10.6(Ubuntu 22.04)을 사용하고 있음
 - 파일 서버(Windows File Server)를 On-premise로 운영하며, 공유폴더를 활용하고 있음
- 네트워크 (논리적 망분리)
 - VLAN 기반의 논리적 망분리 형태로 운영하고 있음
 - 상담사 PC(1인 1 PC)는 하나의 PC가 업무망 VLAN과 인터넷망 VLAN에 동시 접속됨
 - √ 업무망 접근은 VDI 게이트웨이(하랑항공 CRM), 사내 CTI/DB 서버로의 접근만 허용하고 있음
 - √ 인터넷망 접근은 인터넷 사용이 가능함 (단, 하단 보안 관리 현황 참조)
 - 재택·외근 접속 시 SSL-VPN(TLS 1.3) 의무화, VPN 접속 시 ID/PW + OTP 이중 인증(MFA) 적용
 - 인터넷 경계 구간에 방화벽과 내부망 IDS 설치·운영 중

5. (자체 점검) 보안 관리 현황

5.1 내부 관리 계획 및 조직

- 침해사고 대응절차서 보유, CPO→IT보안팀→위탁사 보고체계 명시, 모의훈련 미실시
- IT 시스템 장애 대응 절차서 보유, CTI·녹취 서버 장애 대응 절차 포함
- 내부관리계획서 내 CISO 성명·직책 명시
- 정규직·계약직·파견직 전 취급자 보안서약서 징구 완료
- 사무실 출입구 스피드게이트와 NFC RF카드 이중 인증 운영, 방문자 성명·소속·목적·출입시간 기록 관리, 출입 이력 시스템 자동 기록
- 서버실 출입구 지문인식 시건장치 이중 통제 운영
- 보안 캐비닛 잠금 미흡

5.2 접근 통제 및 권한 관리

- 계정 목록·취급자 명단 대조 불필요 계정 미발견, 임시 계정 만료 시 자동 비활성화
- 역할별 최소 권한 기준서 보유, 외부 직원(파견·협력사) DB 직접 접근 권한 검증 누락
- 신청→부서장→IT인프라팀 3단계 품의 승인 운영
- 인사시스템과 계정관리시스템이 연동
- 개인정보 취급자 부여/변경/삭제 기록 보존 1년
- IT인프라팀 전원 공용계정 공동 사용
- VDI 20분·CTI 15분·DB 30분 세션 타임아웃, 화면보호기 5분 GPO 강제 적용, 전 시스템 적용 확인

5.3 접속기록 보관 및 점검

- CTI·상담로그 DB·VDI 접속 로그 자동 생성, 계정 식별자·접속일시·IP·고객ID·조회·변경·삭제 항목 포함
- 월 1회 정기 검토 기준 내부관리계획서 명시, 약 4개월간 접속기록 정기 검토 미실시
- 로그 보관 기간 6개월, 6개월 경과 후 자동 삭제
- 월 1회 백업 실시, 운영 서버와 동일 물리 서버 내 저장

5.4 비밀번호 관리

- 2종류 이상 조합 10자리·3종류 이상 조합 8자리 복잡도, 90일 유효기간·최근 5회 재사용 금지 기술적 강제 적용
- GPO 화면보호기 5분 강제 적용, 해제 시 비밀번호 요구, 사용자 임의 변경 차단

5.5 접속 보안 및 네트워크

- SSL-VPN 의무화, VPN 미접속 시 개인정보처리시스템 포트 방화벽 차단
- 방화벽 최소 허용 원칙 운영, 내부망 IDS 운영
- VLAN 기반 논리적 망분리 운영
- P2P·도박·성인 사이트 차단, 개인 이메일·클라우드 스토리지 접근 허용 상태
- WPA3-Enterprise(802.1X) 암호화, 인증된 단말기만 접속 허용, 게스트 무선랜 별도 VLAN 분리 운영

5.6 단말기 보안

- 자체 홈페이지 미운영, 외부 공개 서버 없음, 고유식별정보 처리 대상 홈페이지 취약점 점검 위험 구조적 부재
- CTI·녹취·DB 서버 전체 백신 설치
- CTI 스탠바이 서버 OS 보안패치 3개월 이상 미적용
- 공유폴더 접근 권한·암호화·접근 이력 로깅 미적용, 하랑항공 고객 성명·연락처·예약 정보 파일 다수 저장
- AhnLab V3 365 전 단말기 설치, 백신 일 1회 자동 업데이트
- 상담사 PC USB 포트 활성화, GPO 차단·화이트리스트 미적용, 최근 5개월 보조저장매체 관리대장 기록 부재

5.7 개인정보 암호화 및 출력 통제

- 사용자 비밀번호 SHA-256+Salt(32바이트) 일방향 해시 저장, 레거시 MD5/SHA-1 계정 없음
- 고객 휴대폰 번호·성명 VARCHAR 평문 저장
- 위탁사 VDI 세션 TLS 1.3 암호화 적용, 재위탁사((주)스카이에시지) 고객 휴대폰 번호 FTP 평문 전송
- VDI 로컬 드라이브 매핑 차단, IT인프라팀 단말기 DRM 적용 암호화 폴더 저장 규정 운영
- 암호화 키 관리 대장 기록 부재, 소스코드 내 키 평문 하드코딩
- 전사 표준 마스킹 기준서 보유, 주민등록번호·휴대폰·여권번호 마스킹 기술 적용
- 개인정보 복사 시 출력물 관리대장 부재

5.8 개인정보 생명주기

- 계약 범위 외 항목 수신 시 자동 반송·담당자 알림 체계 운영
- CTI 위탁사 코드·DB 스키마 단위 격리, DB 접근 통제 솔루션 적용
- (주)스카이에시지 SMS 발송 재위탁, 하랑항공 사전 서면 승인 확인, 재수탁사 직원 교육 의무·현장 보안 점검·손해배상 책임 조항 누락
- 개인정보 파일 제3자 제공 관리대장 기록 부재
- WPM 완전삭제 솔루션 운영, 전산 파기 이력 확인

- 보유기간 만료 데이터 배치 프로그램 월 1회 식별·파기, DBA 확인 후 영구 삭제 절차 운영
- 상담 3팀·5팀 파기 예정 문서 파쇄기 미사용, 일반 재활용통 투기 사례 현장 확인
- 법령별 분리 보관 기준 수립, 일부 별도 테이블 구현, 법령별 전수 매핑 작업 미완료
- 파기 결과 위탁사 보고 의무 규정·계약서 미명시, 최근 1간 파기 결과 보고 기록 부재

6. 개인정보 재위탁 현황

- (주)스카이메시지: SMS 발송 업무
- 원위탁자(하랑항공) 사전 서면 승인 존재, 재위탁 계약서 체결
- 재위탁 계약서 내 재수탁사 직원 교육 의무 조항, 현장 보안 점검 허용 조항, 손해배상 책임 범위 및 절차 조항이 누락
- (주)스카이메시지에 대한 연 1회 정기 관리·감독(보안 점검) 미실시
- (주)스카이메시지로의 데이터 전송 시 FTP(평문) 방식을 사용하고 있어 전송 구간 암호화가 미적용 상태